IT PROJECT MANAGEMENT · CHAPTER 09

Risk Management

Risk management identifies what might go wrong or right, analyses the likelihood and impact, and plans responses before the risks occur.

PMBOK Guide 7th ed. **ISO 31000:2018** **Case study: Realtime Quiz**

AGENDA

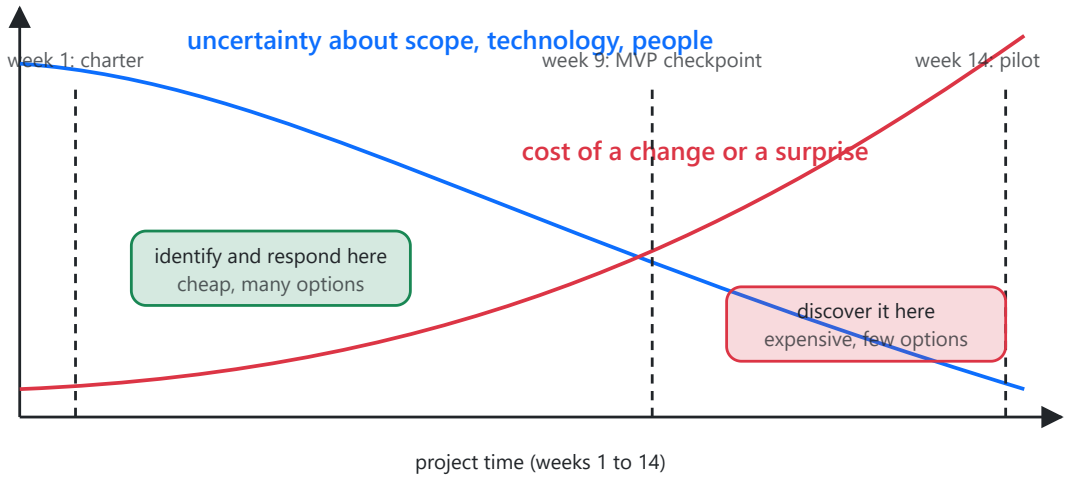
What we will cover

1. Risk, uncertainty, issues and assumptions; threats and opportunities
2. Risk management plan: roles, categories, risk breakdown structure, thresholds
3. Identifying risks: brainstorming, checklists, interviews, SWOT, assumption analysis
4. IT-specific risk sources: technology novelty, integration, security, vendors, staff turnover
5. Qualitative analysis: probability and impact matrix, risk scoring, urgency
6. Quantitative analysis: expected monetary value, decision trees, Monte Carlo simulation
7. Response strategies: avoid, mitigate, transfer, accept; exploit, enhance, share
8. Contingency plans, fallback plans, reserves and triggers
9. Risk register and risk report; monitoring and re-assessment
10. Risk in agile: spikes, prototypes and short feedback loops as risk reduction
11. Chapter Quiz
12. Lab-09

Click any item to jump directly to that topic.

Why manage risk: uncertainty falls, the cost of surprises rises

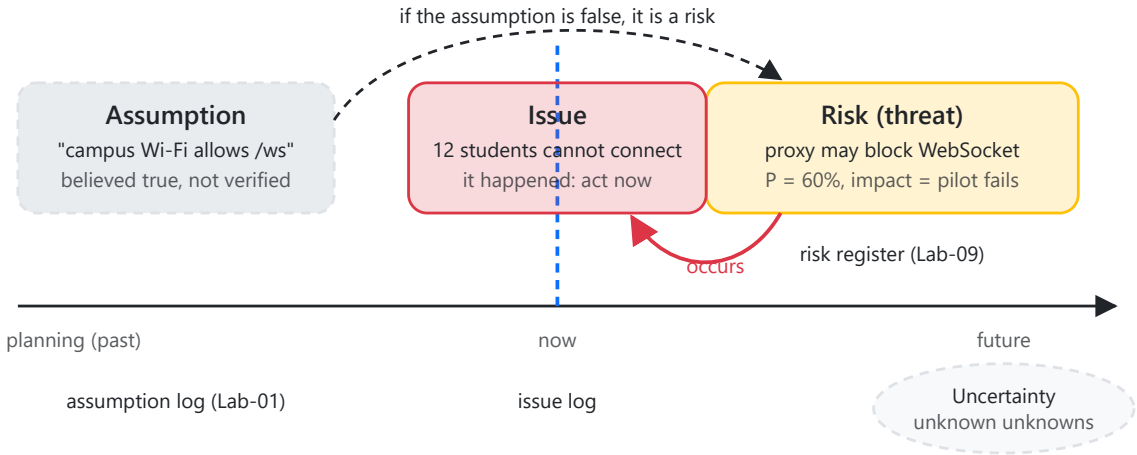
- Chapters 04-08 produced a scope, a schedule, a budget, a quality plan and a team for the **Realtime Quiz** project. Every one of those plans rests on assumptions that may turn out false.
- The Realtime Quiz plan already lists seven risks (newer Spring Boot, scoring races, campus proxy, memory growth, Khmer fonts, scope creep). This chapter gives you the method to find the rest, rank them and decide what to do *before* week 14.
- **PMBOK Guide 7th ed.** makes "optimise risk responses" a principle and "uncertainty" a performance domain; **ISO 31000:2018** defines risk as the effect of uncertainty on objectives.
- Risk management is cheap early and expensive late: a two-day spike in week 5 costs less than a failed pilot in week 14.



TOPIC 1

Risk, uncertainty, issue and assumption are four different things

- **Risk**: an uncertain future event or condition that, if it occurs, has a positive or negative effect on at least one objective (PMBOK Guide). It has a *probability* and an *impact*.
- **Issue**: something that has already happened and needs action now. Probability is 100%; it goes in the issue log, not the risk register.
- **Assumption**: a statement taken as true without proof ("campus Wi-Fi allows WebSocket"). Every unverified assumption hides a risk.
- **Uncertainty**: lack of knowledge. Known unknowns become risks; unknown unknowns are covered by the management reserve.
- ISO 31000: risk is the *effect of uncertainty on objectives*, so an objective must be named for a risk to exist.



Threats and opportunities, written as cause, event and effect

	Threat	Opportunity
Effect	Negative on scope, time, cost or quality	Positive: faster, cheaper, better, more adoption
Example	Campus proxy blocks WebSocket	Reuse the SE-course code base and tests
Response families	Avoid, mitigate, transfer, accept, escalate	Exploit, enhance, share, accept, escalate
Reserve	Adds to the contingency	Reduces it (only if realistic)

A good risk statement separates the **cause** (a fact today), the **event** (uncertain) and the **effect** (on an objective). "Wi-Fi" is not a risk; the sentence on the right is.

```
Risk statement template
  Because <cause, a fact>, <event> may occur,
  which would <effect on scope / time / cost / quality>.

R02  Because the campus proxy inspects HTTP upgrades (fact),
     the WebSocket handshake on /ws may be blocked in the lab
     room (event), so students cannot join the week-14 pilot
     and the go-live objective is missed (effect).

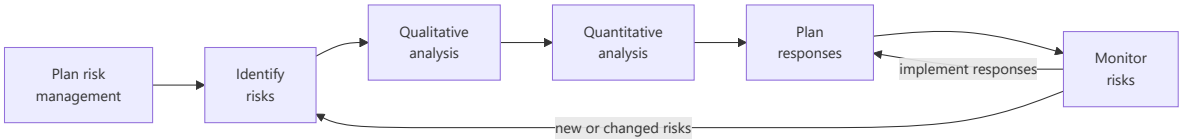
R03  Because mid-semester exams fall in weeks 7-8 (fact),
     team capacity may drop from 40 to 10 hours per week,
     which would delay phases 3-4 by up to two weeks.

O01  Because the same four students build Realtime Quiz in the
     Software Engineering course (fact), the CI pipeline and
     45 tests may be reused (event), saving about 40 hours.

Not a risk:  "Wi-Fi"           (a topic, no event, no effect)
Not a risk:  "the build is red"  (already true: an issue)
```

TOPIC 2

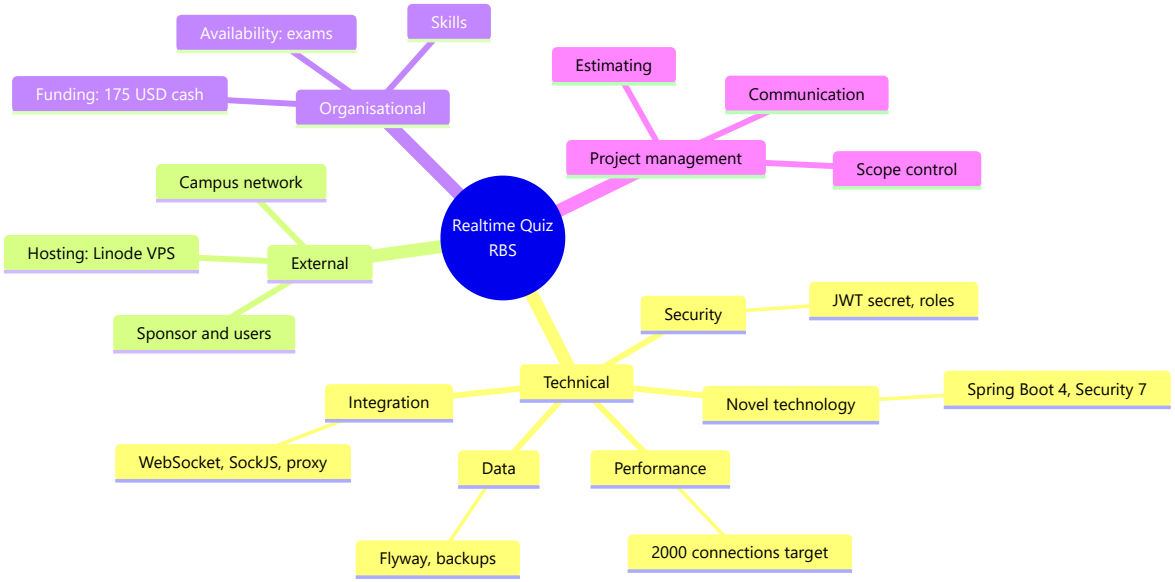
The risk management process is a loop, not a one-off workshop



Step	Output	Realtime Quiz
Plan	Risk management plan	Scales, roles, thresholds, cadence
Identify	Risk register (rows)	20+ risks, RBS category each
Qualitative	P, I, score, rank	Top 10 above threshold 12
Quantitative	EMV, reserve, tree, Monte Carlo	Reserve 64 h, P80 date
Respond	Strategy, actions, owner, trigger	Plans for the top 10
Monitor	Risk report, re-assessment	Every sprint review

⚠ The **plan** step decides *how* risk will be managed (roles, scales, thresholds, cadence) before any risk is listed. Without agreed scales, one student's "high" is another's "medium". PMBOK Guide 7th ed., Process Groups Practice Guide.

Risk breakdown structure: categories that make identification systematic



- The **RBS** is to risks what the WBS is to work: a hierarchy of *sources* of risk. Level 1 categories, level 2 sub-sources, leaves are prompts ("what could go wrong with backups?").
- Each register row gets one RBS category, so you can see at a glance where the project is exposed (Realtime Quiz: 6 of 10 threats are technical).
- **Roles** in the plan: the sponsor sets the risk appetite and owns the management reserve; the PM owns the register and the contingency reserve; each risk has one **risk owner** who watches the trigger and runs the response.
- A category with no risks is a warning sign that the team did not look, not that nothing can go wrong there.

> Mermaid `mindmap` is enough for the RBS in Lab-09; draw.io is fine too.

Worked example: the Realtime Quiz risk management plan (excerpt)

```
## 3. Probability scale
| Level | Name      | Probability | Guide                          |
|-------|-----------|-------------|--------------------------------|
| 1     | Very low  | under 10%   | would surprise everyone        |
| 2     | Low       | 10 to 30%   | has happened to other teams    |
| 3     | Medium    | 30 to 50%   | as likely as not               |
| 4     | High      | 50 to 70%   | expected unless we act         |
| 5     | Very high | over 70%    | almost certain                 |

## 4. Impact scale (effort / schedule / pilot quality)
| Level | Effort lost | Schedule slip | Pilot on 2026-12-18      |
|-------|-------------|---------------|--------------------------|
| 1     | under 4 h   | under 1 day   | not noticeable           |
| 2     | 4 to 16 h   | 1 to 3 days   | minor glitches           |
| 3     | 16 to 40 h  | about 1 week  | one feature missing      |
| 4     | 40 to 80 h  | 2 weeks       | pilot degraded           |
| 5     | over 80 h   | over 2 weeks  | pilot cancelled          |

## 5. Thresholds (score = P x I)
- 12 to 25  High:   response plan and owner mandatory, sponsor informed
- 6 to 10   Medium: owner monitors; plan only if cheaper than the EMV
- 1 to 5    Low:    watch list, re-checked every sprint review
- Overall tolerance: sum of open threat scores under 60 by week 10
```

- **Risk appetite** (sponsor): how much uncertainty the Head of IT accepts for the pilot. Here: "a degraded pilot is acceptable, a cancelled one is not".
- **Risk threshold**: the measurable line where a risk needs a response (score 12) or escalation (any impact-5 risk).
- The scales are **project specific**: an impact of 80 hours is "very high" for a 588-hour project and negligible for a bank.
- Also in the plan: categories (the RBS), roles, review cadence (every sprint review, plus a risk workshop at the MVP checkpoint in week 9), and the reserve rules from Lab-06.

⚠ Write the impact scale in units the team can check (hours, days, pilot outcome), not adjectives only.

Identifying risks: use several techniques, because each one misses something

Technique	How	Finds	Misses
Brainstorming	Whole team, one RBS branch at a time, no debate, 20 minutes	Many candidates fast	Quiet voices, technical depth
Checklist	Standard list of IT risks (novelty, integration, vendor, staff) ticked against the project	The classic risks	Anything new to this project
Interviews	15 minutes each with the sponsor, campus IT, a student from last year	Outside knowledge (proxy rules, exam dates)	Costs time
SWOT	Strengths and weaknesses inside, opportunities and threats outside	Opportunities, organisational risks	Technical detail
Assumption analysis	Take the assumption log of Lab-01; for each ask "what if false?"	Hidden risks in the plans	Risks nobody assumed about
Document review	Read the WBS, schedule, budget and the Realtime Quiz plan's own risk table	Risks already known	Nothing new

SWOT of the Realtime Quiz project (internal rows, external columns):

Strengths	Weaknesses
Same team builds the product in the SE course; CI and 45 tests exist; sponsor is the Head of IT	4 part-time students; no ops experience; single VPS; exams in weeks 7-8
Opportunities	**Threats**
Other courses want live quizzes (O02); free student hosting credits; reuse of SE code (O01)	Campus proxy (R02); Linode outage (R05); Spring Boot 4 newer than tutorials (R07); scope creep (R06)

💡 Output of this step is a **list of risk statements with an RBS category and a proposed owner**. Do not score yet: scoring during brainstorming kills the flow.

Worked example: the Realtime Quiz risk register after identification

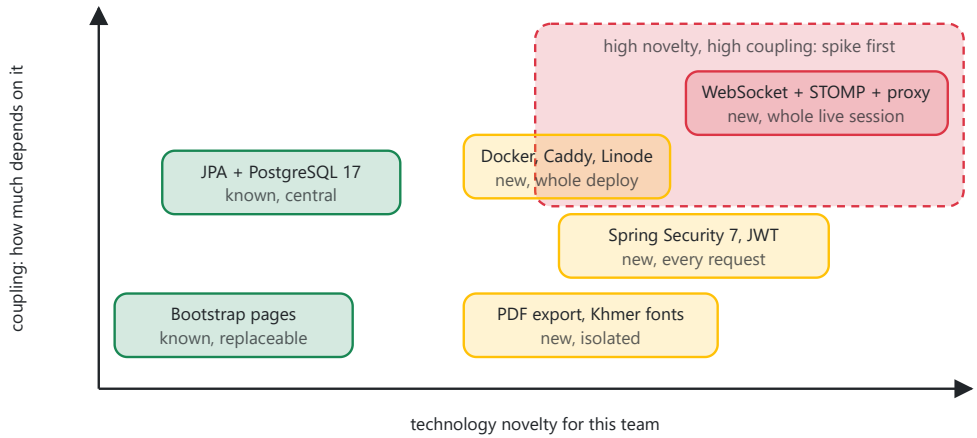
Id	RBS category	Cause (fact)	Event (uncertain)	Effect (objective)	Owner
R01	Technical / performance	Simple in-memory broker, one instance	Broadcast latency over 1 s with 50 phones	Leaderboard out of sync, pilot degraded	Dara (backend)
R02	External / campus network	Campus proxy inspects HTTP upgrades	WebSocket handshake on /ws blocked in the lab room	Students cannot join, pilot fails	Bopha (DevOps)
R03	Organisational / availability	Mid-semester exams in weeks 7-8	Capacity drops from 40 to 10 h per week	Phases 3-4 slip up to 2 weeks	Lecturer (PM)
R04	Technical / security	Secret once placed in application.yml	APP_JWT_SECRET pushed to the public GitHub repo	Forged instructor tokens, results tampered	Dara (backend)
R05	External / hosting	Single Linode VPS, no failover	Outage during the pilot session	Pilot cancelled or rescheduled	Bopha (DevOps)
R06	PM / scope	Sponsor and team like the "Could" features	Chat and media started before the MVP demo	MVP checkpoint (week 9) missed	Lecturer (PM)
R07	Technical / novel technology	Spring Boot 4 and Security 7 newer than tutorials	Team follows Boot 3 guides, security config fails	One week lost in phase 1	Dara (backend)
R08	Technical / data	No automated database backup	Docker volume lost on a VPS rebuild	All quizzes and results lost	Bopha (DevOps)
R09	Technical / data	Flyway migrations differ per vendor	V3 migration fails on PostgreSQL in production	Deployment delayed 2 days	Vireak (QA)
R10	Technical / performance	Load test used 100 simulated clients on a LAN	50 real phones answer within the same second	Slow answers, timeouts on pilot day	Vireak (QA)
O01	Organisational / skills	Same students build the app in the SE course	Code, tests and CI reused from SE labs	About 40 h saved	Lecturer (PM)
O02	External / sponsor	Head of IT wants live quizzes in other courses	Department adopts the platform after the pilot	Year-2 hosting funded, more users	Lecturer (PM)

Team from Lab-08: Dara (backend lead), Sok (frontend lead), Bopha (DevOps and database), Vireak (QA and documentation), the supervising lecturer as project manager. Columns P, I, score and response are added in the next steps.

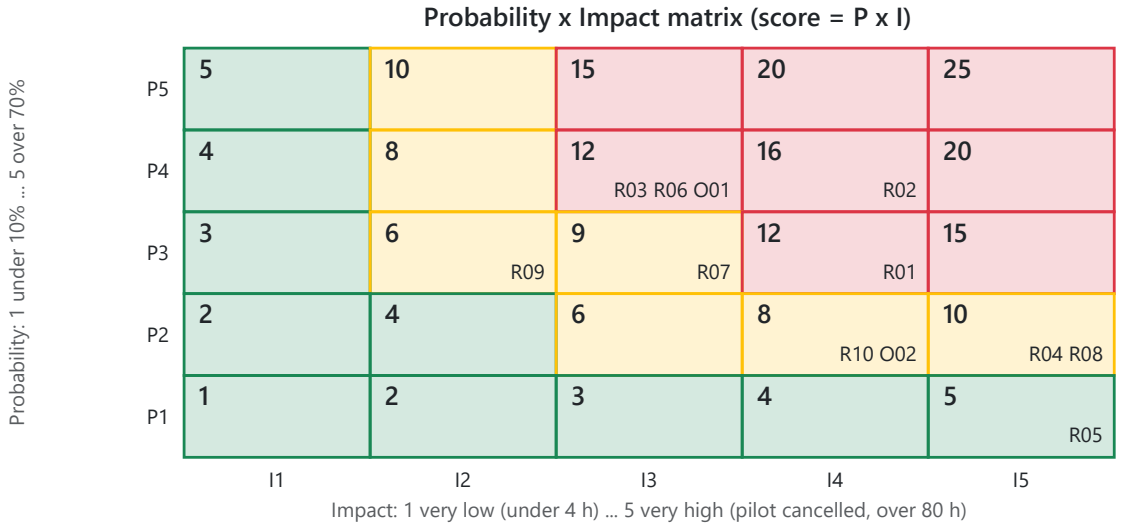
Where IT projects get hurt: novelty, integration, security, vendors, people

Source	Typical event	Realtime Quiz
Technology novelty	Framework version newer than the team's experience or the tutorials	Spring Boot 4.1, Spring Security 7 (R07)
Integration	Two parts work alone, fail together (proxy, browser, broker)	WebSocket through Caddy and the campus proxy (R02)
Performance	Works with 5 users, not with 50 at the same second	Simple broker, 2000-connection target (R01, R10)
Security	Leaked secret, missing role check, injection	APP_JWT_SECRET in git (R04)
Vendors and hosting	Outage, price change, API deprecation	Linode VPS at gicitc.com (R05)
Staff turnover and availability	Key person leaves or is unavailable; knowledge in one head	Exams (R03); only Dara knows the STOMP code
Requirements and scope	Late changes, "Could" features pulled forward	Chat and media before MVP (R06)

⚠ Two IT patterns to remember: **novelty x coupling** (a new component that everything depends on is the riskiest place in the architecture) and **the last 10%** (integration, deployment and load are discovered late unless you test them early).



Qualitative analysis: place every risk on the probability and impact matrix



- **Qualitative** means ordinal scales (1-5) and quick judgement: cheap, done for every risk, good enough to rank.
- Score = **P x I**. Red (12-25) needs a response plan, amber (6-10) an owner who watches, green (1-5) a line on the watch list.
- Rate the impact on the objective that matters most (here: the pilot). An impact-5 risk with P1 (R05, Linode outage) is green by score but still gets a fallback because the plan escalates every impact-5 risk.
- **Urgency** breaks ties: a risk whose trigger can fire next week (R07 in phase 1) beats one whose window is in week 14.
- Other factors from PMBOK: detectability, proximity, controllability, connectivity to other risks.

Worked example: scoring, ranking and urgency for the twelve register rows

Rank	Id	Risk (short)	P	I	Score	Window	Level
1	R02	Campus proxy blocks /ws	4	4	16	wk 9-14	High
2	R03	Exam weeks cut capacity	4	3	12	wk 7-8	High
3	R06	Scope creep before MVP	4	3	12	wk 5-9	High
4	R01	Broker latency at 50 phones	3	4	12	wk 11-14	High
5	R04	JWT secret leaked	2	5	10	any	Medium*
6	R08	Data loss, no backup	2	5	10	wk 10-14	Medium*
7	R07	Spring Security 7 config	3	3	9	wk 2-3	Medium
8	R10	Pilot-day load pattern	2	4	8	wk 14	Medium
9	R09	Flyway migration fails	3	2	6	wk 12	Medium
10	R05	Linode outage on pilot day	1	5	5	wk 14	Low*
-	O01	Reuse SE code and tests	4	3	12	wk 1-4	Exploit
-	O02	Department adoption	2	4	8	after	Enhance

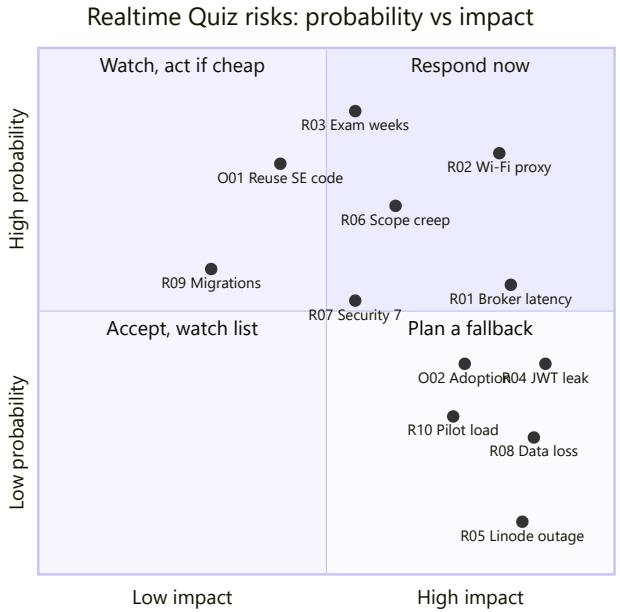
```
Scoring rule (risk management plan, section 5)
  score = P x I            P, I in 1..5
  level = High   if score >= 12
          Medium if 6 <= score <= 10
          Low    if score <= 5
  * any impact 5 is escalated to the sponsor regardless

Ties at 12: R03, R06, R01
  urgency = how soon the trigger can fire
  R03 window wk 7-8  -> act first (exam dates are known)
  R06 window wk 5-9  -> second
  R01 window wk 11-14 -> third, but the spike is in wk 5

Total open threat score = 16+12+12+12+10+10+9+8+6+5 = 100
Plan tolerance: under 60 by week 10 -> responses needed

Spreadsheet (risk-register.csv opened in Calc):
  F2 = D2*E2                 score
  G2 = IF(F2>=12,"High",IF(F2>=6,"Medium","Low"))
  sort by F descending, then by window ascending
```

The same register as a Mermaid quadrant chart (you will draw this in Lab-09)




```
quadrantChart
  title Realtime Quiz risks: probability vs impact
  x-axis Low impact --> High impact
  y-axis Low probability --> High probability
  quadrant-1 Respond now
  quadrant-2 Watch, act if cheap
  quadrant-3 Accept, watch list
  quadrant-4 Plan a fallback
  R02 Wi-Fi proxy: [0.80, 0.80]
  R03 Exam weeks: [0.55, 0.88]
  R01 Broker latency: [0.82, 0.55]
  R05 Linode outage: [0.84, 0.10]
  O01 Reuse SE code: [0.42, 0.78]
  ...
```

Coordinates are P/5 and I/5, nudged slightly so labels do not overlap. Quadrant 4 (high impact, low probability) is where fallback plans live: R05 has a low score but a ready fallback because its impact is 5.

Quantitative analysis: expected monetary value sizes the contingency reserve

```
EMV = probability x impact (in money or hours)
Convention from Lab-06: 1 student hour = 5 USD internal rate

R01  Broker latency at 50 phones
     P = 0.4 (level 3, mid of 30-50%)
     impact if it occurs = 60 h rework (relay to RabbitMQ)
     EMV = 0.4 x 60 h = 24 h  = 24 x 5 = 120 USD

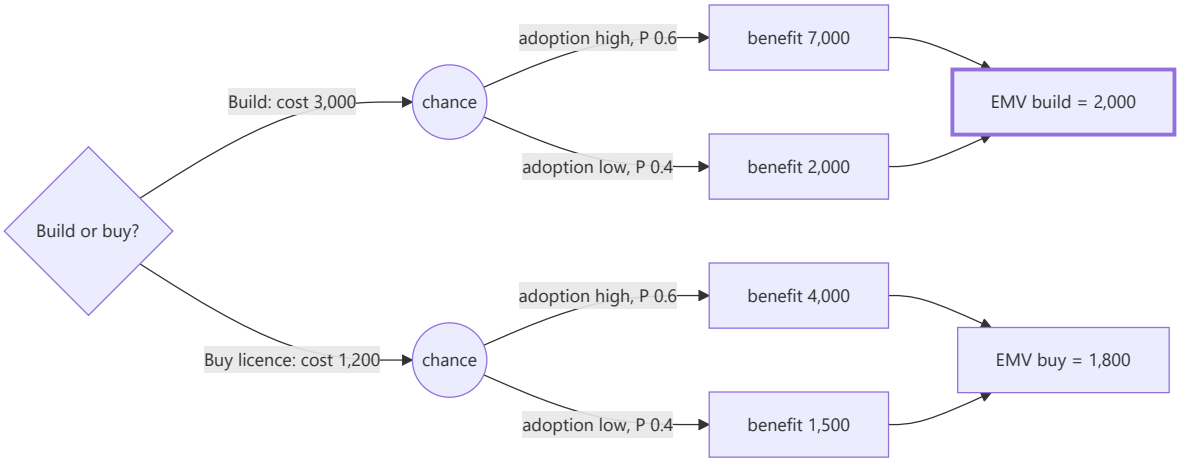
R03  Exam weeks cut capacity
     P = 0.6 (level 4), impact = 40 h of lost work
     EMV = 0.6 x 40 h = 24 h  = 120 USD

Contingency reserve = sum of EMV(threats) - sum of EMV(opportunities)
  R02  0.6 x 30 h = 18 h        R04  0.2 x 20 h =  4 h
  R01  0.4 x 60 h = 24 h        O01 -0.6 x 40 h = -24 h
  R03  0.6 x 40 h = 24 h
  R06  0.6 x 30 h = 18 h        threats 88 h, opportunity -24 h
  ------------------------------------------------------------
  Reserve = 88 - 24 = 64 h  (11% of the 588 h baseline, 320 USD)
```

- **Quantitative** analysis uses numbers (hours, USD, days) instead of 1-5 levels. Do it only for the top risks and for decisions worth the effort.
- **EMV** is the average outcome if the project were run many times. No single run costs exactly 24 h: either R01 happens (60 h) or not (0 h). The reserve is a *portfolio* bet across all risks.
- The reserve derived here (64 h) is compared with the percentage reserve assumed in Lab-06 (10% = 56 h). The larger, justified number wins and the budget is updated.
- Opportunities reduce the reserve only when the response (exploit) is committed; otherwise treat them as 0.
- Cash reserve is separate: one spare month of Linode (25 USD) for R05.

⚠ Do not convert the 1-5 *level* straight into a probability. Use the midpoint of the level's range (level 3 = 30-50% gives 0.4).

Decision tree: build Realtime Quiz or buy a quiz SaaS, with uncertain adoption



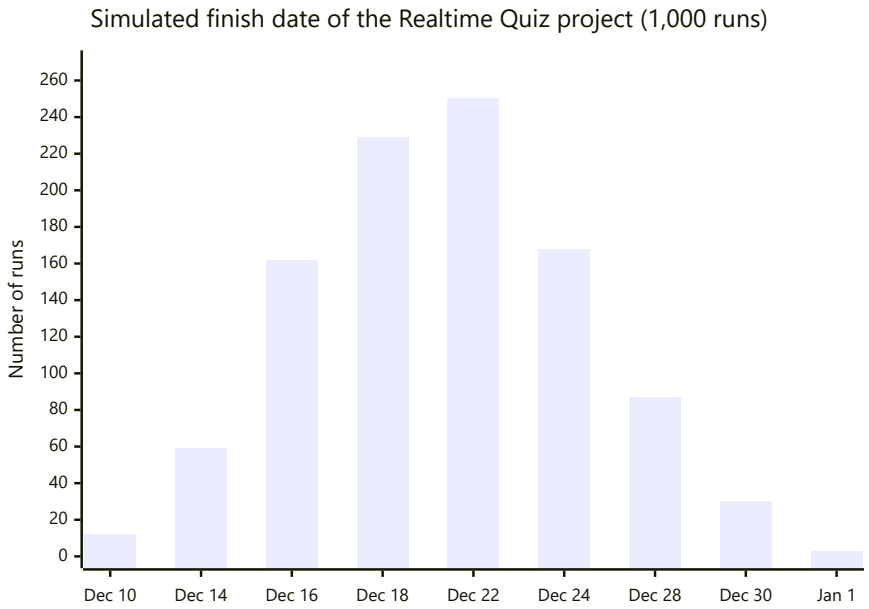

```
Values: department benefit over 2 years,
USD-equivalent (lecturer hours saved)

EMV(build) = 0.6 x 7,000 + 0.4 x 2,000 - 3,000
           = 4,200 + 800 - 3,000 = 2,000
EMV(buy)   = 0.6 x 4,000 + 0.4 x 1,500 - 1,200
           = 2,400 + 600 - 1,200 = 1,800

Decision: build (higher EMV by 200)

Sensitivity: build wins while
  5,000p - 1,000 > 2,500p + 300
  p > 0.52
So the decision flips if adoption
probability falls below 52%: a small
margin. Response: enhance O02 (adoption)
with a demo to two other lecturers.
```

Monte Carlo: simulate the schedule 1,000 times and read the P50 and P80 dates




```
Method (Lab-05 PERT estimates as input)
1. For each activity take (O, M, P).
2. Each run: draw a duration between O and P
   (triangular around M), for every activity.
3. Add the critical path -> one finish date.
4. Repeat 1,000 times; count runs per date.

Reading the histogram (bins of 2 working days)
  planned finish (Lab-05): Fri 2026-12-18, day 70
  runs finishing by Dec 18: 12+59+162+229 = 462
  P(on time)  = 46%
  P50 (500th run) = day 71, Mon Dec 21 (Dec 22 bin)
  P80 (800th run) = day 74, Thu Dec 24
  -> promise the pilot for Dec 18 only with a
     4 working-day schedule reserve, or commit
     to the P80 date.
```

The Lab-09 challenge builds this simulation in a spreadsheet or a short Python script.

Response strategies for threats and for opportunities

Threat	Meaning	Realtime Quiz example
Avoid	Change the plan so the risk cannot occur (P = 0)	R06: freeze scope at the MVP checkpoint; no "Could" feature before week 9
Mitigate	Reduce probability or impact	R02: enable SockJS fallback and test from the lab room in week 9
Transfer	Move the impact to a third party (insurance, contract, SLA)	R08: managed PostgreSQL backups from the hosting provider (cost 5 USD/month)
Accept	Do nothing now; passive, or active with a contingency	R09: accept, keep 4 h in reserve for a migration fix
Escalate	Outside the project's authority; hand to the sponsor	R05: the Head of IT decides whether a second VPS is funded
Opportunity	**Meaning**	**Realtime Quiz example**
Exploit	Make sure it happens (P = 1)	O01: fork the SE repository on day 1; reuse CI and tests
Enhance	Increase probability or benefit	O02: invite two other lecturers to the pilot demo
Share	Partner with someone better placed to capture it	Share the platform with the department in exchange for hosting
Accept	Take it if it comes	Free student hosting credits

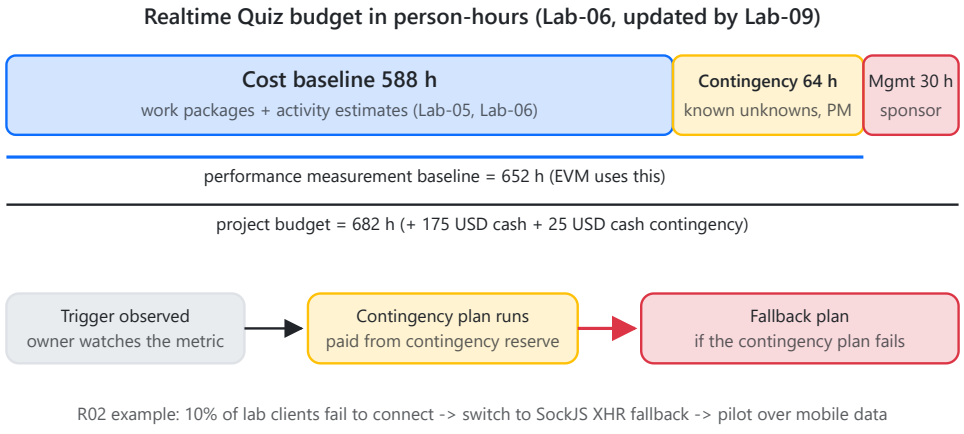
- Choose the strategy by comparing the **cost of the response** with the **EMV** of the risk: mitigating R02 costs 6 h and removes an 18 h EMV, so it pays.
- Avoidance is the strongest but usually costs scope or freedom; acceptance is free until the risk occurs.
- Transfer moves money, not responsibility: the pilot still fails if the provider's backup is empty.
- A response can create a **secondary risk** (switching to a hotspot introduces a data-cost risk) and leave a **residual risk** (SockJS fallback is slower).
- Terms: PMBOK Guide 7th ed.; ISO 31000 calls the same activity "risk treatment".

One strategy per risk, several *actions* per strategy. "Mitigate" alone is not a plan: the actions, owner and trigger are.

TOPIC 8

Contingency plan, fallback plan, reserves and the trigger that connects them

- **Trigger** (warning sign): a measurable condition that tells the owner the risk is about to occur or has occurred. "More than 10% of test clients fail to connect from the lab room."
- **Contingency plan**: prepared actions executed when the trigger fires, paid from the **contingency reserve** that the PM controls.
- **Fallback plan**: what to do if the contingency plan does not work either ("plan C"): run the pilot over the students' mobile data.
- **Contingency reserve** covers known unknowns (identified risks, sized by EMV). **Management reserve** covers unknown unknowns, is owned by the sponsor and is not part of the cost baseline.
- Using reserve is not failure; using it without a register entry is.



R02 example: 10% of lab clients fail to connect -> switch to SockJS XHR fallback -> pilot over mobile data

Worked example: the response plan for R02, campus proxy blocks WebSocket

```
### R02 · Campus proxy blocks the WebSocket handshake
- Category: External / campus network      Score: P4 x I4 = 16 (High)
- Owner: Bopha (DevOps)                    Reviewed: every sprint review
- Strategy: MITIGATE (reduce P and I), residual risk accepted

Preventive actions (before the trigger)
1. Enable the SockJS fallback (XHR streaming) in WebSocketConfig  wk 6, 2 h
2. Ask campus IT to whitelist wss://gicitc.com/ws                 wk 6, 1 h
3. Connection test from the lab room with 10 phones              wk 9, 3 h
   Cost of prevention: 6 h  (EMV removed: 0.6 x 30 h = 18 h)

Trigger: more than 10% of the week-9 test clients fail to connect,
         or the /actuator metric app.ws.connections stays below the
         number of joined participants for 30 s during the pilot

Contingency plan (when the trigger fires)      reserve: 8 h
- Force SockJS transport "xhr-streaming" on the play page (1 h)
- Move the session to the department's guest Wi-Fi (0.5 h)

Fallback plan: students join over mobile data; instructor shares
the join code on the projector. Secondary risk S02-1: data cost for
students (Low, accept). Residual risk: 1 s slower updates (accept).
```

Field	Why it must be there
Owner	One person watches the trigger; "the team" watches nothing
Strategy	One word from the seven, so the intent is clear
Actions, date, cost	Go into the schedule and budget of Labs 05-06
Trigger	Measurable, so the decision to act is not an argument
Contingency + reserve	Money and time set aside now, not begged for later
Fallback	Plan C for an impact-4 or impact-5 risk
Secondary, residual	New risks created and what remains after the response

☑ After planning, re-score: R02 drops to P2 x I3 = 6 (Medium). The register keeps both the original and the residual score.

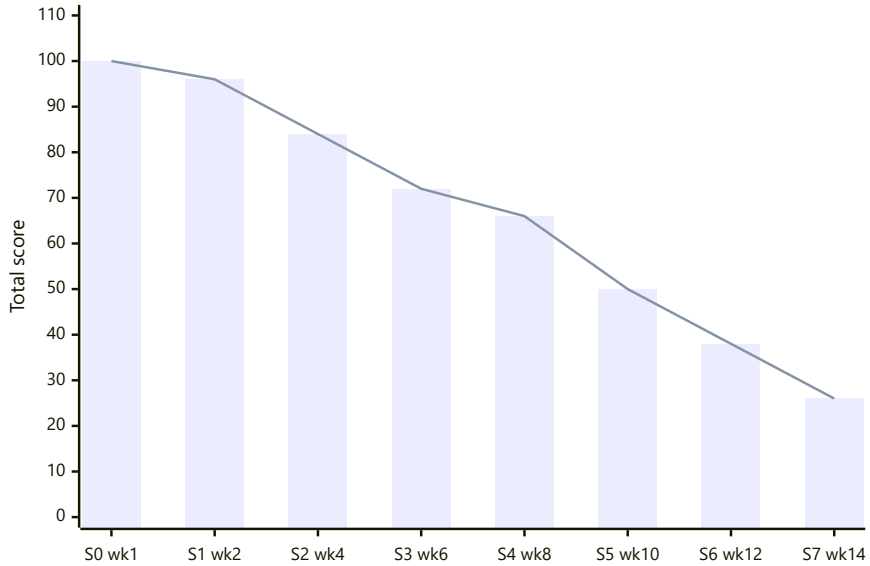
The risk register is the database; the risk report is the story for the sponsor

```
# Risk report · Realtime Quiz · sprint 4 review (week 8)
Overall exposure: open threat score 66 (was 100 in week 1,
tolerance under 60 by week 10: on track). Reserve used: 12 of 64 h.

Top risks now
| Id  | Risk                     | Score | Trend | Next action        |
|-----|--------------------------|-------|-------|--------------------|
| R02 | Proxy blocks /ws         | 6     | down  | lab-room test wk 9 |
| R01 | Broker latency           | 12    | flat  | load test wk 11    |
| R06 | Scope creep              | 6     | down  | scope frozen wk 9  |
| R11 | Sok unavailable (new)    | 8     | new   | pair on play page  |

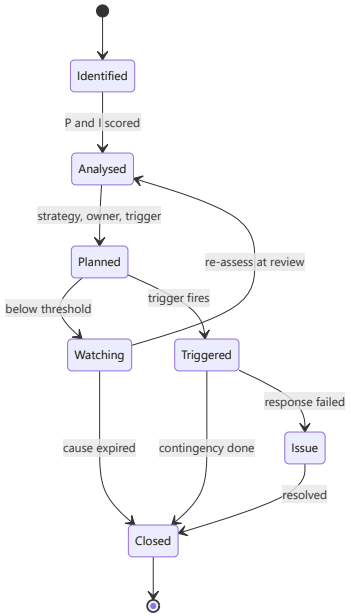
Materialised: R03 exam weeks. Capacity fell to 12 h/week in weeks
7-8; contingency (re-sequenced phase 4 tests) used 12 h of reserve.
Closed: R07 (Security config done, no issue), R09 (migrations pass).
Decisions requested: fund a spare Linode month (25 USD) for R05.
```

Risk burndown: sum of open threat scores per sprint



The register holds every column (id, category, cause, event, effect, owner, P, I, score, strategy, actions, trigger, reserve, status, residual score). The report summarises trend, top risks, materialised and closed risks, reserve use and decisions needed.

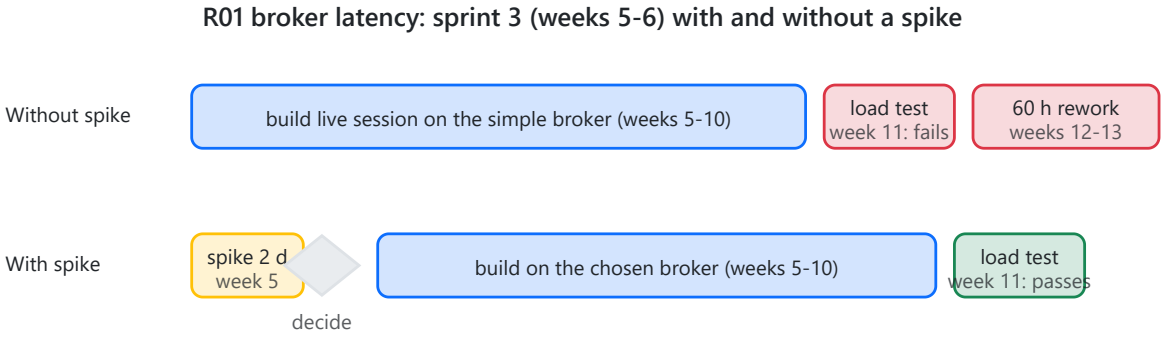
Monitoring: risks change state, so the register is reviewed on a cadence



When	Who	What
Daily stand-up	Team	Any trigger observed? Any new risk?
Sprint review (every 2 weeks)	PM, owners	Re-score open risks, close expired ones, update the burndown, write the risk report
MVP checkpoint (week 9)	Team, sponsor	Full re-identification workshop; reserve reconciled with the budget
Materialised risk	Owner, PM	Risk review meeting within 2 days: what happened, response taken, reserve used, lessons, register update
Project close	PM	Which risks occurred, which responses worked: lessons learned

- **Re-assessment** changes P and I as the project learns (after the week-9 test R02 drops from 16 to 6).
- **Risk audits** check the process: are owners watching triggers, is the reserve tracked?
- **Reserve analysis**: reserve remaining vs risk remaining. 52 h left for 66 points of open score is comfortable; 5 h left for 66 points is not.

Risk in agile: a spike buys information before the team commits



Spike card (time-boxed, 2 days, output is knowledge, not a feature)

Question: does the simple broker keep broadcast latency under 500 ms with 100 clients?
Method: WebSocketStompClient with 100 threads, measure QUESTION_OPENED fan-out on the VPS
Exit: latency chart + decision (keep simple broker / RabbitMQ relay); risk R01 re-scored

- Agile does not skip risk management; it moves it into the **backlog**: a **spike** is a time-boxed research item whose output is a decision, not shippable code.
- **Prototype** (throw-away or evolutionary): shows the riskiest part of the product early, for example the play page on 10 real phones in week 6.
- **Short feedback loops** (sprint review, CI on every push, demo to the sponsor every two weeks) turn big late surprises into small early ones.
- Order the backlog by **risk and value**: the Realtime Quiz milestones put the live session core (phase 3) before analytics (phase 5) for that reason.
- Agile Practice Guide 2017: risk is addressed by iteration, not eliminated by planning.

Every agile practice is a risk response in disguise

Practice	Risk it reduces	Strategy	Realtime Quiz
Spike	Technology novelty, performance unknowns	Mitigate (reduce P)	Broker latency spike in week 5 (R01)
Prototype / walking skeleton	Integration surprises at the end	Mitigate (reduce I)	Phase 0: deployed "hello" on the Linode VPS in week 1
Sprint review and demo	Building the wrong thing; sponsor surprise	Mitigate	Demo to the Head of IT every two weeks
Definition of Done, CI	Quality debt discovered late	Mitigate	45 tests, coverage 80%, CI green before merge
Time-boxing and scope freeze	Scope creep, endless polishing	Avoid	MVP checkpoint week 9 (R06)
Pair programming, shared ownership	Key-person dependency	Mitigate	Sok pairs with Dara on the STOMP code
Feature toggles, small releases	Big-bang deployment failure	Mitigate	Chat behind a toggle; deploy weekly from week 10
Retrospective	Repeating the same mistakes	Monitor	Risk review is a standing retrospective item

```
## Backlog item · SPIKE-03 (sprint 3, 2 days)
Title: Can the simple broker serve 100 clients?
Risk: R01 (score 12, High)
Time box: 2 days (Dara), ends 2026-10-13

Acceptance
- [ ] 100 STOMP clients connected to the VPS
- [ ] fan-out latency measured for 10 questions
- [ ] chart committed to docs/spikes/spike-03.md
- [ ] decision recorded in the register
      (keep broker / RabbitMQ relay)
- [ ] R01 re-scored at the sprint review
```

💡 Scrum Guide 2020 has no "risk register", but the Sprint Review and the ordered Product Backlog are its risk tools. In a hybrid course project you keep both: the register for the sponsor, the backlog for the team.

WRAP-UP

Best practices and common mistakes

1 Write cause, event, effect

"Wi-Fi" is a topic. "Because the proxy inspects upgrades, /ws may be blocked, so the pilot fails" is a risk you can score and own.

2 Agree the scales first

Probability ranges and impact in hours and pilot outcome, written in the plan, before the first risk is scored.

3 One owner, one trigger

Every high risk has a named owner and a measurable trigger. "The team monitors it" means nobody does.

4 Size the reserve from EMV

A flat 10% is a guess; 64 h derived from the top risks is an argument the sponsor can accept or challenge.

5 Attack the high-novelty, high-coupling parts early

Spike the broker in week 5, deploy to the VPS in week 1, test from the lab room in week 9. Integration and load are never "later" items.

6 Review on a cadence

Re-score at every sprint review, run a workshop at the MVP checkpoint, hold a review meeting within two days of a materialised risk.

✕ Mistake: issues in the register

"The build is red" has already happened. It belongs in the issue log with an action, not in the register with a probability.

✕ Mistake: write-only register

A register filled in week 1 and never opened again protects nobody. The burndown chart exposes this immediately.

✕ Mistake: threats only

Reusing the SE code base saves 40 hours if someone exploits it on day 1. Opportunities need owners and actions too.

Chapter quiz 10 questions

1. The build has been red since Monday and nobody can deploy. Where does this belong?

- In the risk register with P = 5
- In the issue log, with an action and an owner
- In the assumption log
- In the management reserve

2. Risk R01 has probability 0.4 and an impact of 60 hours if it occurs. Its EMV is:

- 60 h
- 24 h
- 150 h
- 0.4 h

3. A risk is rated P = 4 and I = 4 on the 1-5 scales, and the plan says 12 or more is High. What follows?

- Score 8, medium: the owner watches it
- Score 16, high: a response plan and an owner are mandatory
- Score 16, but only impact-5 risks need a plan
- Score 4 x 4 = 8, low

4. The top threats have EMVs of 18, 24, 24, 18 and 4 hours; a committed opportunity has an EMV of -24 hours. The contingency reserve is:

- 88 h
- 112 h
- 64 h
- 24 h

5. Build costs 3,000 and yields 7,000 with P = 0.6 or 2,000 with P = 0.4. EMV of the build branch is:

- 2,000
- 5,000
- 4,200
- 9,000

6. Paying the hosting provider for managed database backups so that a data loss no longer hits the project is which strategy?

- Avoid
- Mitigate
- Transfer
- Accept

7. Which list contains only opportunity response strategies?

- Exploit, enhance, share, accept
- Avoid, mitigate, transfer, accept
- Exploit, mitigate, share, escalate
- Enhance, transfer, accept, avoid

8. Who controls the management reserve and what does it cover?

- The PM; identified risks sized by EMV
- The sponsor; unknown unknowns outside the cost baseline
- The risk owner; the contingency plan of one risk
- The team; schedule buffer on the critical path

9. A Monte Carlo run of the schedule gives a P80 date of 24 December. This means:

- The project will finish on 24 December
- 80% of the simulated runs finished on or before 24 December
- The planned date has an 80% chance
- 20% of activities finish after 24 December

10. In an agile project, what is a spike?

- A sprint with extra hours to catch up
- A time-boxed investigation whose output is knowledge or a decision, not a feature
- A high-priority bug fix
- The peak of the risk burndown chart

WRAP-UP

Summary

A risk is an uncertain future event with an effect on an objective; an issue has happened; an assumption is unverified; unknown unknowns are uncertainty.

The risk management plan fixes roles, the RBS, the probability and impact scales, thresholds and the review cadence before any risk is scored.

Identify with several techniques (brainstorming, checklist, interviews, SWOT, assumption analysis) and write every risk as cause, event, effect.

IT projects are hurt by novelty, integration, performance, security, vendors and people; novelty x coupling marks the spot to spike first.

Qualitative: score = P x I on the 5x5 matrix, rank, break ties by urgency; high risks need a response plan.

Quantitative: EMV = P x impact sizes the contingency reserve (64 h for Realtime Quiz); decision trees compare options; Monte Carlo gives P50 and P80 dates.

Threats: avoid, mitigate, transfer, accept, escalate. Opportunities: exploit, enhance, share, accept. Compare response cost with EMV.

A response plan has an owner, actions, a measurable trigger, a contingency paid from the PM's reserve and a fallback; the sponsor holds the management reserve.

Monitor on a cadence with a risk report and burndown; in agile, spikes, prototypes and short feedback loops are the risk responses.

Open Lab-09: 5 tasks + 1 challenge

Next chapter: 10 · Communication Management